

Security+ 2.4 · Application Attacks

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — Application Attacks (11:48)**

· [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Aplicação = a superfície mais atacada: privilege escalation (horizontal = mesmo nível, outro dado; vertical = tier acima — user vira admin); directory traversal (../etc/passwd); remote code execution. Defesa: input validation, patching, WAF, SCA (library vulnerable), secure coding.

💡 Highlights que a prova cobra

- Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)
- Directory traversal: sobe com ../ pra /etc/passwd
- Defesa: input validation SEMPRE; nunca confie no input

🎯 Dicas de prova & Cenários Típicos

- 'user gains higher-level access' = privilege escalation (vertical)
- 'path traversal reads arbitrary files' = directory traversal

Cenário clássico de exame: Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizontal; 'usuário vira admin' = vertical.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — Application Attacks)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:

- A) Escalada de privilégio (privilege escalation)
- B) Negação de serviço
- C) Engenharia social
- D) Sniffing

2. Injeção de comando SQL num campo de login explora principalmente a falta de:

- A) Criptografia do disco
- B) Validação de entrada (input)
- C) Backup
- D) Antivírus

3. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)...

4. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Directory traversal: sobe com ../ pra /etc/passwd'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc/passwd...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa: input validation SEMPRE; nunca confie no input'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Defesa: input validation SEMPRE; nunca confie no input...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: "user gains higher-level access" = privilege escalation (vertical). Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'user gains higher-level access' = privilege escalation (vertical)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: "path traversal reads arbitrary files" = directory traversal. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'path traversal reads arbitrary files' = directory traversal...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizontal; 'usuário vira admin' = vertical.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizont...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)...

10. Cenário corporativo (Application Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Directory traversal: sobe com ../ pra /etc/passwd'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc/passwd...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Escalada de privilégio (privilege escalation).

✓ **Por que está certa:** A escalada de privilégio (privilege escalation) é a técnica na qual um atacante, após obter acesso inicial com um usuário comum, explora vulnerabilidades, falhas de configuração ou credenciais mal protegidas para elevar seu nível de permissão dentro do sistema. No contexto do CompTIA Security+ (SY0-701), esse conceito é classificado como uma tática de pós-exploração (TA0004 no MITRE ATT&CK) e pode ser vertical (de usuário comum para administrador) ou horizontal (de um usuário para outro com privilégios semelhantes). O enunciado descreve exatamente a transição de 'usuário comum' para 'Domain Admin', que é o exemplo clássico de escalada vertical de privilégios em ambientes Windows Active Directory. Portanto, a opção correta é a que identifica esse movimento como privilege escalation.

✗ **Por que as outras estão erradas:**

- *Negação de serviço:* Negação de serviço (DoS) é um ataque que visa tornar um recurso, serviço ou rede indisponível para usuários legítimos, geralmente por meio de sobrecarga de requisições, esgotamento de recursos ou exploração de falhas que causam travamento. No cenário descrito, o atacante não está tentando derrubar o serviço, mas sim obter mais poder dentro do domínio. A negação de serviço não envolve elevação de privilégios; ela afeta a disponibilidade, não a confidencialidade ou integridade das permissões. Portanto, não se aplica ao ganho de poder de usuário comum para Domain Admin.
- *Engenharia social:* Engenharia social é a manipulação psicológica de pessoas para que revelem informações confidenciais ou executem ações que comprometam a segurança, como clicar em links maliciosos ou fornecer credenciais. Embora a engenharia social possa ser um vetor inicial para obter acesso, ela não descreve o processo técnico de elevação de privilégios dentro do sistema. O enunciado foca no ganho de poder após o acesso, não no método de obtenção inicial. Portanto, engenharia social não é a classificação correta para a transformação de usuário comum em Domain Admin.
- *Sniffing:* Sniffing (ou eavesdropping) é a interceptação passiva de tráfego de rede para capturar dados sensíveis, como credenciais em texto claro ou informações de sessão. É uma técnica de coleta de informações, não de elevação de privilégios. Mesmo que o sniffing possa levar à obtenção de credenciais administrativas, ele não é o ato de escalar privilégios em si. O enunciado descreve o resultado final (tornar-se Domain Admin), não o método de captura de tráfego. Portanto, sniffing não é a resposta correta para classificar o ganho de poder.

2) B — Validação de entrada (input).

✓ **Por que está certa:** A alternativa correta é 'Validação de entrada (input)'. A injeção de comando SQL (SQLi) ocorre quando uma aplicação concatena dados fornecidos pelo usuário diretamente em uma consulta SQL sem sanitização ou parametrização adequada. No contexto de um campo de login, o atacante insere caracteres especiais (como aspas simples, comentários SQL, operadores lógicos) para manipular a lógica da consulta, por exemplo, transformando 'SELECT * FROM usuarios WHERE user='admin' AND pass='senha' em uma condição sempre verdadeira ('OR 1=1 --'). A causa raiz é a ausência de validação de entrada, que deveria garantir que os dados recebidos estejam em conformidade com o formato esperado (ex.: apenas caracteres alfanuméricos, comprimento máximo) e, mais importante, o uso de consultas parametrizadas (prepared statements) que separam o código SQL dos dados. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.3), enfatiza a validação de entrada como controle fundamental para prevenir injeções. Portanto, a falha principal explorada é a falta de validação de entrada.

✗ **Por que as outras estão erradas:**

- *Criptografia do disco*: Criptografia de disco (ex.: BitLocker, LUKS) protege os dados em repouso, garantindo confidencialidade caso o dispositivo físico seja roubado. Ela não tem relação com a lógica de uma consulta SQL em tempo de execução. Mesmo com disco totalmente criptografado, uma injeção SQL ainda funcionaria, pois o ataque ocorre na camada de aplicação, não no armazenamento. Portanto, é uma tecnologia de proteção de dados em repouso, não um controle de validação de entrada.
- *Backup*: Backup é um processo de cópia de dados para recuperação em caso de perda, corrupção ou desastre. Embora seja essencial para a continuidade de negócios, não impede que uma injeção SQL seja executada. Um backup pode ajudar a restaurar dados após um ataque bem-sucedido, mas não aborda a causa raiz da vulnerabilidade. A injeção SQL explora a falta de validação na entrada, não a ausência de cópias de segurança.
- *Antivírus*: Antivírus é um software que detecta e remove códigos maliciosos conhecidos, como vírus, worms e trojans, baseando-se em assinaturas ou heurística. Ele não analisa o tráfego de entrada de uma aplicação web em busca de comandos SQL maliciosos. Uma injeção SQL é um ataque de aplicação que pode ser executado sem qualquer malware no servidor ou no cliente. Portanto, o antivírus não é um controle eficaz contra injeção SQL; a defesa correta é a validação de entrada e consultas parametrizadas.

3) D — Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc/passwd....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Directory traversal: sobe com ../ pra /etc/passwd.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: Defesa: input validation SEMPRE; nunca confie no input....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Defesa: input validation SEMPRE; nunca confie no input.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'user gains higher-level access' = privilege escalation (vertical)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): 'user gains higher-level access' = privilege escalation (vertical).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: 'path traversal reads arbitrary files' = directory traversal....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): 'path traversal reads arbitrary files' = directory traversal.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizont....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Cenário: 'usuário comum acessa a conta de outro usuário' = privesc horizontal; 'usuário vira admin' = vertical..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Directory traversal: sobe com ../ pra /etc/passwd....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Application Attacks): Directory traversal: sobe com ../ pra /etc/passwd.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

